Product Requirements Document

DeFi Contract Auditor (working name): pre-deployment security and privilege-risk analysis for Solidity smart contracts

Version 0.1 (draft for review) | October 25, 2026
Status: specification stage, nothing described here is built yet
Companion documents: Context Document, Feature List, Market Research

Item	Detail
Product	DeFi Contract Auditor (working name). Advisory pre-flight analysis for Solidity contracts.
Document owner	Founder / product lead (to be assigned)
Audience	Founders, engineers, designers, security advisers, early investors
Related engineering docs	README, AGENTS, backend_architecture, analysis_pipeline, features, api_endpoints, api_calls, frontend_architecture, security_and_guardrails, testing_and_evaluation, build_plan
Scope of this PRD	What we are building, why, and for whom. Engineering detail lives in the engineering docs.

1. Summary

DeFi Contract Auditor is a pre-deployment, **advisory** analysis tool for Solidity smart contracts. A developer uploads code and, within minutes, receives three things: (1) a **Privilege Map** that shows which keys and roles can do dangerous things, with a plain-English worst case for each; (2) **evidence-backed security findings** with exact code locations; and (3) **verified patch suggestions** shown as red/green diffs.

The product is built to be run **before** a formal audit, to catch cheap problems early and make the formal audit faster. It is not a replacement for a human audit, a certification, or legal advice.

> **Core product principle**
> Deterministic tools find and verify. The language model explains and drafts. No evidence, no finding.

2. Problem

Teams shipping smart contracts face a hard trade-off: formal review is expensive and slow, while the cost of a missed flaw is permanent and often total.

Evidence	What the research shows (as of Oct 2026)
Audit cost	2026 market references put most DeFi protocol audits at $25,000 to $100,000, with an overall range of $5,000 to $250,000+. Remediation re-audits add roughly $5,000 to $20,000 per pass (Sherlock pricing reference, Feb 2026; vendor source).

Evidence	What the research shows (as of Oct 2026)
Audit time	Scope-driven: about 500 lines of non-comment code is roughly 3 days in a contest model and 6,000 lines roughly 38 days, before scheduling queues and remediation. We could not verify the 3 to 6 month figure from the original brief, so this PRD says 'weeks to months including scheduling'.
Cost of failure	CertiK counted about $3.35B lost across 630 incidents in 2025; Chainalysis estimated more than $3.4B stolen. For H1 2026, CertiK reports about $1.32B (344 incidents) and Immunefi about $972M (207 incidents, a record count).
Recovery	Immunefi's CEO states that nearly 80% of heavily hacked projects fail to fully recover.
Tooling gap	Classic static scanners are noisy and mostly pattern-based. A 2026 educational source counts 27+ open-source and 25+ commercial AI auditing tools, and names false-positive noise as the main trust problem.

Honest framing of the opportunity
A large share of the biggest losses come from compromised wallets, keys and infrastructure rather than novel code bugs. No source-code tool can see everything. This product addresses the code-visible part, including over-powered admin roles that turn a single key compromise into a catastrophe.

3. Goals and Non-Goals

Product goals

- **G1 Fast pre-flight.** A useful report in under 5 minutes; median under 3 minutes for a 500-line contract.
- **G2 Make admin risk obvious.** Any founder, even non-technical, understands who can drain, mint, pause or upgrade, and what limits abuse.
- **G3 Trustworthy output.** Every finding carries verifiable evidence. Target unsupported-claim rate under 1% on the evaluation set.
- **G4 Better audits, not fewer audits.** Users arrive at a formal audit with trivial issues fixed (hypothesis to measure in beta).
- **G5 Code confidentiality.** Customer code is private, short-lived and never used for training.

Non-goals

- Replacing formal audits, issuing certifications, or promising that code is 'safe' or 'secure'.
- Legal or regulatory verdicts. Compliance mapping is deferred (see Section 5).
- Post-deployment monitoring, wallet tracking or on-chain transaction analysis.
- Non-EVM chains and languages in the first release.

4. Target Users

Persona	Who they are	Job to be done	Success looks like
A. Early-stage founder / smart contract developer (primary)	Small team, limited budget, launch pressure, may not have a security specialist.	Quickly learn what could go wrong and who holds dangerous powers, before paying for or scheduling a formal audit.	Fixes issues in an afternoon; walks into the formal audit with a cleaner codebase and a clear admin-risk story for investors.
B. Freelance / independent security auditor	Reviews code for clients, paid by time, needs speed and consistency.	Triage a new codebase faster, see privileged functions and candidate issues with line references.	Saves review hours; every candidate finding is quick to verify or dismiss.
C. DeFi compliance manager (secondary, later phase)	Responsible for cross-border regulatory alignment of token mechanics.	Flag contract mechanics that raise regulatory questions for counsel.	Served only after the regulatory corpus phase. Output is questions for counsel, never verdicts.

5. Scope and Phasing

The scope has been deliberately narrowed from the original concept so the first releases are buildable and defensible. The flagship feature is the Privilege Map, which is largely deterministic and needs no retrieval system.

Phase	Contents	Indicative effort
MVP (M0 to M3)	Accounts and projects, upload and compile, semantic analysis, **Privilege Map** with holder declarations, static findings, coverage statement, reports (JSON, Markdown, SARIF).	5 to 8 weeks
Phase 2 (M4 to M5)	Security evidence library (small curated corpus) with grounding verifier; verified patch generation with red/green diff review.	4 to 5 weeks
Phase 3 (M6 to M7)	Prove-it exploit tests (fails on original, passes on patched); Invariant Hunter Lite using template invariants by contract type.	4 to 6 weeks
Phase 4 (M8)	Hardening, sandbox upgrade, PDF export, CI integration, red-team pass, closed beta.	3 to 4 weeks
Deferred	Regulatory RAG and jurisdiction toggle; LLM-inferred invariants; config-aware analysis; PR-diff audits; multi-contract system analysis; other chains; self-hosted deployment.	Not scheduled

Effort figures are rough estimates for a small team or agent-assisted build and assume phases run in sequence.

> **Why compliance is deferred**
> India's crypto framework is still largely tax-led (30% tax plus 1% TDS on virtual digital asset gains). Reporting indicates a regulatory discussion paper could arrive later in 2026, possibly covering DeFi and staking, and the RBI told a parliamentary panel in July 2026 that VDAs should not get legal recognition now. A compliance corpus built on moving rules would be thin and quickly stale, which is a main reason it is deferred. If compliance returns, the EU's MiCA (fully applicable since December 2024) offers a more stable starting corpus.

6. Functional Requirements (summary)

Full user stories and acceptance criteria are in the Feature List. Priorities: P0 = needed for MVP, P1 = needed for a credible product, P2 = differentiator, build after P0/P1.

ID	Requirement	Pri	Phase
FR-01	Upload a .sol file or zip (Foundry/Hardhat); create projects and audits; live progress; cancel and delete.	P0	MVP
FR-02	Compile in an isolated sandbox with pinned toolchain; return compiler diagnostics on failure; never fall back to unverified text-only review.	P0	MVP
FR-03	Extract a semantic model (functions, modifiers, roles, external calls, upgradeability, token flows).	P0	MVP
FR-04	**Privilege Map**: roles, powers, mitigations, blast-radius score, worst-case sentence, role-admin escalation.	P0	MVP
FR-05	Optional role-holder declaration (single wallet, multisig, timelock + multisig, renounced); live recompute; 'assumed' label when undeclared.	P0	MVP
FR-06	Static findings from Slither and custom detectors with exact line spans and severity.	P0	MVP
FR-07	Coverage statement on every report: analyzed, not analyzed, out of scope.	P0	MVP
FR-08	Evidence requirement: every finding has at least one evidence record (static fact, retrieved citation, or reproduced proof).	P0	MVP
FR-09	Reports: JSON, Markdown, SARIF now; PDF later. Disclaimer in every format.	P1	MVP / M8
FR-10	Security evidence library with exact-quote citations and 'no precedent retrieved' state.	P1	Phase 2
FR-11	Verified patches: compile, re-scan, no new high/critical, gas delta when tests exist; edit-and-reverify.	P1	Phase 2
FR-12	Separate, unscored 'unverified observations' list for model-only hypotheses.	P1	Phase 2
FR-13	Prove-it: runnable exploit test that fails on original and passes on patched code.	P2	Phase 3
FR-14	Invariant Hunter Lite: template invariants for ERC-20, ERC-4626, staking, lending; counterexample call sequences.	P2	Phase 3
FR-15	API keys and CI usage; organization isolation; configurable retention and immediate deletion.	P1	MVP / M8

7. Non-Functional Requirements

Area	Requirement
Performance	Time to first report: median under 3 minutes for a 500-line contract (including model stages); Privilege Map recompute after a declaration change under 300 ms.
Accuracy	Privilege detection at least 90% on power categories and 95% on role detection on the labeled set; retrieval recall at 5 of at least 0.85; unsupported-claim rate under 1%; false-positive rate on High/Critical findings under about 30% on audited-clean code.
Security	No user script ever executes outside a network-less sandbox; non-root, read-only filesystem, resource limits; dependency fetching isolated and allow-listed; strict tenant isolation (row-level security).
Privacy	Source encrypted in transit and at rest; default retention 24 hours, user-deletable immediately; never embedded in shared indexes, never logged, never used for training; model providers under zero-retention terms.
Reliability	Stages idempotent and checkpointed; graceful degradation (for example, skip retrieval if the vector store is down and say so in the coverage statement).
Accessibility and UX	Dark theme by default, WCAG AA contrast, keyboard-navigable graph with a table alternative, severity never conveyed by color alone.
Language rules	Never state or imply 'safe', 'secure', 'audited', 'certified' or 'compliant'. Use 'no verified issues detected by this analysis'. Score is labeled a heuristic risk indicator.
Compatibility	Solidity on EVM chains for v1; Foundry, Hardhat and loose-file projects.

8. Success Metrics

Category	Metric	Initial target
Activation	Share of uploads that produce a report	Above 80% (build failures are the main risk)
Speed	Median time to first report	Under 3 minutes (500 lines)
Trust	High/Critical findings judged valid by auditors in beta	At least 60%
Trust	Unsupported-claim rate on evaluation set	Under 1%
Value	Patch acceptance rate	Above 50%
Value	Privilege Map judged accurate by reviewers	At least 90% of roles and powers correct
Retention	Users who run a second audit within 30 days	To be set after beta baseline
Safety	Confidentiality incidents; cross-tenant access events	Zero
Business	Pricing, conversion and revenue targets	Not yet defined, see Market Research

9. Assumptions and Dependencies

- Founders are willing to upload pre-release code to a hosted service if retention is short and controls are clear. This is an assumption, to be tested in interviews; a self-hosted option is deferred.
- Upstream tools (Slither, Foundry, solc) remain maintained; versions are pinned.

- A language-model provider is available under zero-retention, no-training terms, or a self-hosted model is used for sensitive tiers.
- Security corpus sources can be used under their licenses by storing our own summaries, short permitted excerpts and links.
- Real-world repositories often fail to compile on the first try; build robustness is a core engineering investment, not an afterthought.

10. Risks and Mitigations

Risk	Why it matters	Mitigation
General frontier agents commoditize 'a model reads your code'	Public benchmarks show frontier agents detecting a large share of known vulnerabilities and exploiting many (EVMbench, SCONE-bench).	Compete on verification, workflow, privilege view, privacy and trust, not raw model reasoning. Use deterministic tools as ground truth.
Crowded AI-auditor market	Established players (for example Sherlock's Audit Engine, launched 2026) and venture-funded startups are moving into self-serve AI review.	Narrow wedge (Privilege Map plus pre-flight), founder-friendly UX, audit-readiness hand-off pack, partnerships with human auditors.
False sense of security	Users may skip formal audits or market a 'score' as a badge.	Coverage statement above the score, mandatory disclaimer, no badge feature, terms forbidding marketing as certification.
Build and parse failures	Many real repos do not compile cleanly.	Robust dependency fetch, compiler selection, clear diagnostics, Tree-sitter-only fallback.
Privilege heuristic errors	Wrong classification destroys trust in the flagship feature.	Fixed taxonomy, one tested matcher per category, fall back to 'other privileged' rather than guess, expand labeled fixtures.
Retrieval noise or licensing	Weak citations or copyright exposure.	Class filters, calibrated threshold, 'no precedent' state, own summaries plus links.
Platform becomes a honeypot	A store of unpatched vulnerabilities is valuable to attackers.	Short retention, per-tenant encryption, access audit logs, minimal data sent to models.
Misuse of exploit tests	Offensive use.	Run only against submitted code in sandbox, not exported by default, rate limits, no weaponized write-ups.

11. Open Questions

- Should role-holder declaration be required (more accurate, more friction) or stay optional with a pessimistic default? Current assumption: optional.
- Pricing and packaging: free tier scope, team plans, per-audit credits, auditor plan. Needs customer interviews.
- Hosted only for launch, or an early self-hosted option for sensitive customers?
- Which human-audit partners (if any) to integrate for a hand-off pack?
- Final product name; the original 'Real-Time Fraud' wording conflicts with the pre-deployment scope.

Appendix A. Standard Disclaimer

> This report is generated by an automated advisory tool. It does not guarantee the security of any smart contract, does not constitute a formal audit, and is not legal advice or a certification of regulatory compliance. Consult qualified security auditors and legal counsel before deployment.

Data points in Section 2 are drawn from public sources listed in the Market Research document. Figures from different publishers use different methodologies and are not interchangeable.